

Super App Security Kit

Índice

1. Introducción

- Alcance del kit
- Público objetivo
- Principios básicos de seguridad (CIA)

2. Manual de Mejores Prácticas

- Autenticación segura (MFA)
- Gestión de contraseñas
- Cifrado de datos (en tránsito y en reposo)
- Control de acceso y roles

3. Checklist de Configuración Segura

- Infraestructura
- Aplicación
- APIs

4. Pruebas Básicas de Vulnerabilidades

- OWASP ZAP (DAST)
- SAST básico

5. Concientización del Equipo

- Phishing
- Ingeniería social
- Buenas prácticas diarias

6. Respuesta a Incidentes (Nice-to-have)

- Flujo de remediación básica

7. Glosario

- GDPR, PCI DSS, MFA, SAST, DAST

Introducción

Alcance del kit (Personal No Técnico)

Este kit está diseñado para equipos pequeños que desarrollan apps financieras y necesitan implementar controles mínimos de seguridad sin contar con infraestructura avanzada o personal de Ciberseguridad, o que no cuenten con el presupuesto necesario para invertir.

Público objetivo :

- Startups fintech
- Equipos de desarrollo
- Product owners
- Emprendimientos sin área de ciberseguridad
- Preventivo
- Práctico
- De bajo costo

Principios básicos de seguridad (CIA)

- Confidencialidad: Solo usuarios autorizados acceden a la información.
- Integridad: Los datos no deben alterarse sin permiso.
- Disponibilidad: Los sistemas deben estar accesibles cuando se necesitan.

Nota: En este kit nos enfocamos principalmente en confidencialidad e integridad.

Manual de Buenas Prácticas

Autenticación Segura

Consideramos que este proceso es fundamental, ya que el manejo de información sensible requiere controles estrictos de acceso. Una autenticación inadecuada podría permitir que personas no autorizadas comprometan la infraestructura, generen interrupciones operativas y provoquen la pérdida o exposición de datos pertenecientes a otros usuarios.

Usar contraseñas fuertes, ejemplo de contraseña :

```
@ContraseñaSegura.com.ar2026
```

Incluir en la contraseña : Símbolos, Mayúsculas & Minúsculas, números.

Usuario + Contraseña = Autenticación básica

Usuario + Contraseña + Código SMS/App = Autenticación multifactor

¿Qué es MFA (Multi-Factor Authentication)?

MFA agrega una segunda capa de seguridad además de la contraseña.

Factores posibles:

- Algo que sabes → contraseña
- Algo que tienes → celular, app autenticadora
- Algo que eres → huella, reconocimiento facial

Guía paso a paso para implementar MFA (nivel básico)

1. Es fundamental identificar y clasificar las cuentas críticas, así como al personal que posee acceso a información confidencial o a sistemas de alto nivel de privilegio, con el fin de aplicar controles de seguridad más estrictos y reducir el riesgo de accesos no autorizados.
 - Administradores
 - Cuentas con acceso a datos financieros
2. Elegir un segundo factor
 - App autenticadora (Google Authenticator, Microsoft, Kaseya (Pago)).
 - SMS (menos seguro, pero aceptable como inicio)
3. Forzar MFA en login
 - Activar MFA obligatorio para usuarios privilegiados
4. Proveer códigos de respaldo
 - Para recuperación de cuenta
5. Registrar eventos de autenticación
 - Logins exitosos
 - Intentos fallidos (Máximo 3 intentos)

Gestión de Contraseñas

Buenas prácticas

- Longitud mínima: 12 caracteres (Utilizar , Minúsculas + Mayúsculas + Símbolos + Números)

- No reutilizar contraseñas
- No almacenar contraseñas en texto plano y tampoco dejarlas al descubierto en el escritorio o directorios de windows
- Usar gestores de contraseñas (Bitwarden & KeePass) Para generar contraseñas robustas.

Plantilla de Política de Contraseñas

```Markdown

# Política de Contraseñas

- Longitud mínima: 12 caracteres
- Debe incluir letras y números
- Rotación cada 90 días
- Bloqueo tras 3 intentos fallidos
- Prohibido compartir credenciales

---

## Cifrado de Datos

### Cifrado en tránsito

Protege los datos cuando viajan por la red.

Usar HTTPS / TLS en toda la aplicación

```
http:// ❌ → inseguro
https:// ✅ → cifrado
```

### Cifrado en reposo

Protege los datos almacenados (bases de datos, backups).

Buenas prácticas:

- Cifrar bases de datos
- Cifrar backups
- Proteger claves de cifrado

Regla simple: Si almacena datos financieros o personales, debe estar cifrado.

---

## Control de Acceso

Principio de menor privilegio:

Un usuario solo debe tener los permisos estrictamente necesarios.

Ejemplo:

- Usuario normal → ver su información
- Admin → gestionar usuarios

Autenticación → Quién eres?

Autorización → Qué puedes hacer?

---